LEZIONE 02

Leggere un bollettino di sicurezza senza perdersi

Un avviso di sicurezza è fatto sempre delle stesse quattro cose, nello stesso ordine: un codice, un punteggio, una riga di lettere, un elenco di prodotti. Qui le leggiamo una alla volta su un avviso vero, e alla fine sai rispondere all'unica domanda che conta: mi riguarda?

A COLPO D'OCCHIO

CVE	2023	23397
il catalogo	anno di assegnazione	numero progressivo

Bassa 0,1–3,9	Media 4,0–6,9	Alta 7,0–8,9	Critica

Il punteggio CVSS dice quanto sia grave la falla, non quanto sia probabile che qualcuno la usi.

Cosa c'è in un avviso

Un avviso ti arriva per mail dal produttore, dal CSIRT, da uno scanner. Comunque sia scritto, dentro trovi sempre queste quattro cose:

Cosa	Come si presenta	A cosa risponde
il **codice**	`CVE-2023-23397`	di quale falla stiamo parlando
il **punteggio**	`9.8`	quanto è grave, in astratto
il **vettore**	`AV:N/AC:L/PR:N/UI:N/...`	come si sfrutta: da dove, con cosa
i **prodotti colpiti**	«Outlook 2013, 2016, 2019, Microsoft 365»	mi riguarda?

Le trovi tutte e quattro sulla stessa pagina: cerca il codice su **nvd.nist.gov**, la banca dati pubblica dei CVE. La pagina di ogni CVE ha sempre lo stesso indirizzo, `nvd.nist.gov/vuln/detail/` seguito dal codice: quella dell'esempio è https://nvd.nist.gov/vuln/detail/CVE-2023-23397. In alto c'è la descrizione, nel

riquadro «Severity» ci sono il punteggio e, accanto, la riga del vettore; più in basso l'elenco dei prodotti e delle versioni. L'avviso del produttore ha le stesse cose, scritte con parole sue.

L'esempio: una falla di Outlook

Il 14 marzo 2023 Microsoft ha pubblicato l'avviso per **CVE-2023-23397**, una vulnerabilità di Outlook per Windows. In parole semplici: arrivava una mail costruita apposta e Outlook, nel momento in cui scattava un promemoria, mandava a un server dell'attaccante l'impronta della password di Windows dell'utente (l'hash NTLM), che si può riusare o rompere con calma. L'utente non doveva aprire niente: bastava che Outlook fosse acceso.

La scelgo perché Outlook ce l'hanno tutti, e perché ha tutte e quattro le cose da leggere. Andiamo con ordine.

1. Il codice: CVE e CWE

CVE-2023-23397 è il nome della falla. Un **CVE** (*Common Vulnerabilities and Exposures*) è un codice univoco, `CVE-anno-numero`, che identifica **una** vulnerabilità in **un** prodotto. Serve perché il produttore, chi l'ha scoperta, il tuo scanner e il bollettino del CSIRT chiamino la stessa cosa con lo stesso nome. I codici li assegnano le CNA (i grandi produttori, i CERT nazionali) coordinate da MITRE: Microsoft è una CNA e il codice se l'è dato da sola.

Accanto al codice l'NVD scrive un secondo codice, il **CWE** (*Common Weakness Enumeration*): non è la falla, è il **tipo di difetto**. Per Outlook è CWE-294, «riuso di una credenziale catturata». I tipi che tornano più spesso:

CWE	Tipo di difetto	In parole
CWE-79	Cross-Site Scripting (XSS)	far eseguire codice nel browser di chi visita un sito
CWE-89	SQL Injection	far eseguire comandi alla banca dati di un sito
CWE-787	Out-of-bounds Write	scrivere in memoria dove non si dovrebbe, fino a prendere il controllo
CWE-22	Path Traversal	leggere file fuori dalla cartella permessa
CWE-294	Capture-replay	catturare una credenziale e riusarla

Per capirsi: il CWE è la classe («SQL injection»), il CVE è il caso concreto («la SQL injection in quel prodotto, quella versione»). Il CWE ti serve a capire che genere di guaio sia; a decidere l'urgenza servono le altre tre cose.

2. Il punteggio: il CVSS

9.8 è il punteggio **CVSS** (*Common Vulnerability Scoring System*), da 0 a 10. Le fasce:

Punteggio	Gravità
0.1–3.9	bassa
4.0–6.9	media
7.0–8.9	alta
9.0–10.0	critica

Il punteggio misura quanto sia grave la falla **in astratto**: non sa se il prodotto ce l'abbia, non sa se sia esposto a Internet, non sa se qualcuno la stia usando davvero (per questo c'è un secondo numero, l'EPSS, nella lezione 3). Un 9.8 su un programma che non hai vale zero. Quindi il punteggio da solo non basta: serve sapere **come** si arrivi a quel numero, e questo lo dice la riga subito accanto.

3. Il vettore: da dove viene il punteggio

Il **vettore** è la riga di lettere che sta accanto al punteggio, sull'NVD nel riquadro «Severity» alla voce «Vector». Per Outlook è:

`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`

È lo scontrino del punteggio: il 9.8 è calcolato da queste otto coppie, e leggendole capisci perché la falla sia grave e, soprattutto, se lo sia **per te**. Ogni coppia è `sigla:valore`, separata dalle barre. Il `CVSS:3.1` all'inizio dice solo la versione del metodo e si salta.

Si legge da sinistra a destra ed è in due metà. **Le prime quattro coppie dicono quanto sia facile entrare**: da dove si attacca, quanto è difficile, con quali credenziali, con quale aiuto dell'utente. **Le ultime quattro dicono cosa succeda dopo**: se il danno resta dentro al programma colpito e quanto si perde. Per decidere l'urgenza bastano le prime quattro; le ultime spiegano il numero.

Prima metà: quanto è facile entrare

Sigla	Si legge	Valori	Per te
`AV`	*Attack Vector*, da dove si attacca	`N` dalla rete · `A` dalla rete locale · `L` dalla macchina stessa · `P` con accesso fisico	`N` su qualcosa raggiungibile da Internet è il caso urgente; `A` serve essere già dentro; `L` e `P` servono già un accesso
`AC`	*Attack Complexity*, quanto è difficile	`L` bassa · `H` alta	`L`: funziona al primo colpo; `H`: servono condizioni che l'attaccante non controlla
`PR`	*Privileges Required*, che credenziali servono	`N` nessuna · `L` un utente qualsiasi · `H` un amministratore	`N`: chiunque; `L` / `H`: serve già aver rubato una password
`UI`	*User Interaction*, serve l'aiuto di qualcuno	`N` nessuno · `R` sì	`R` di solito vuol dire un clic o un file aperto; `N` vuol dire che la formazione non c'entra

Seconda metà: cosa succede dopo

Sigla	Si legge	Valori	Per te
`S`	*Scope*, il danno resta dentro?	`U` resta nel programma colpito · `C` passa ad altri sistemi	`C` è l'apparato da cui si entra in tutta la rete
`C`	*Confidentiality*, quanto si legge	`N` niente · `L` qualcosa · `H` tutto	`H`: dati, password, configurazioni
`I`	*Integrity*, quanto si modifica	`N` · `L` · `H`	`H`: l'attaccante può cambiare o eseguire quello che vuole
`A`	*Availability*, quanto si ferma	`N` · `L` · `H`	`H`: il programma o il servizio si spegne

Ora rileggi il vettore di Outlook con la tabella sotto gli occhi:

- `AV:N` — si attacca dalla rete: basta mandare una mail;
- `AC:L` — senza difficoltà: funziona al primo colpo;
- `PR:N` — senza credenziali: l'attaccante non deve avere niente di tuo;
- `UI:N` — senza che l'utente faccia niente: nessun clic, nessun allegato aperto;
- `S:U` — il danno resta nel programma colpito;
- `C:H / I:H / A:H` — si perde tutto: la password esce, e con quella l'attaccante fa quello che vuole.

Dalla rete, senza sforzo, senza credenziali, senza un clic: è il caso peggiore della prima metà, e per questo fa 9.8. E dice una cosa che il numero da solo non diceva: con `UI:N`, nessuna formazione ai colleghi avrebbe cambiato niente. L'unica difesa era l'aggiornamento.

Il `CVSS:3.1` in testa al vettore dice quale versione del metodo di punteggio sia stata usata. Dalla fine del 2023 esiste il CVSS 4.0 (è il metodo che cambia, non il codice CVE, che resta lo stesso), e gli avvisi più recenti riportano spesso tutti e due i vettori. Il 4.0 ha qualche sigla in più (`AT` per le condizioni d'attacco, e la seconda metà sdoppiata fra il sistema colpito e gli altri): le prime quattro, quelle che ti servono per decidere, sono le stesse.

In pratica: una falla `AV:N` e `PR:N` su qualcosa raggiungibile da Internet è quella da cui partire. Una `AV:L` con `PR:H` su un server interno può aspettare il giro mensile. In mezzo ci sono i casi di tutti i giorni; la tabella li mette in fila, dal più urgente:

Vettore	Dov'è il prodotto	Cosa vuol dire	Quando
`AV:N` `PR:N` `UI:N`	esposto a Internet (firewall, VPN, posta, sito)	chiunque, da fuori, senza niente di tuo e senza aiuto	oggi, prima di tutto il resto
`AV:N` `PR:N` `UI:N`	solo in rete interna	come sopra, ma deve essere già dentro: è il secondo passo di un attacco, non il primo	questa settimana
`AV:N` `PR:N` `UI:R`	sul PC di tutti (browser, Office, lettore PDF)	basta una pagina o un file aperto; con cento colleghi, succede	questa settimana; nel frattempo gli aggiornamenti automatici devono essere accesi
`AV:N` `PR:L`	esposto a Internet	serve un utente qualsiasi: con una password rubata o un account ex dipendente non chiuso ci arriva	questa settimana, e intanto controlla gli account
`AV:N` `AC:H` `PR:N`	esposto a Internet	da fuori senza credenziali, ma servono condizioni che l'attaccante non controlla: spesso diventano `AC:L` quando esce la PoC	questa settimana, non dopo
`AV:A` `PR:N`	solo in rete interna (switch, stampanti, telecamere)	serve una presa di rete o il WiFi: l'ospite in sala riunioni, un PC già compromesso	giro mensile, prima se la rete è piatta
`AV:L` `PR:L`	server interno	serve già essere su quella macchina con un utente	giro mensile
`AV:L` `PR:H`	server interno	serve già essere amministratore di quella macchina: chi lo è ha già tutto	giro mensile, in coda
`AV:P`	qualsiasi	serve toccare l'apparato	giro mensile, o quando passi di lì

Il punteggio da solo non riproduce quest'ordine: la terza riga può avere un 8.8 e la seconda un 9.8, ma a un'azienda con cento PC fa più paura la terza. Il vettore letto insieme alla colonna «dov'è il prodotto» sì, ed è per questo che l'inventario ha la colonna «raggiungibile da Internet».

4. I prodotti colpiti: la risposta a «mi riguarda?»

Tutto quello sopra dice quanto sia grave. L'ultima parte dell'avviso dice se sia tua. Per Outlook l'elenco è: Outlook 2013 SP1, Outlook 2016, Office 2019, Office LTSC 2021, Microsoft 365 Apps. Tutte le versioni di Outlook per Windows in uso in quel momento. Outlook per Mac, per telefono e la posta via browser no.

Sull'NVD lo stesso elenco è scritto in un formato suo, il **CPE** (*Common Platform Enumeration*). Una riga per prodotto, per esempio:

`cpe:2.3:a:microsoft:outlook:2016:*:*:*:*:*:*:*`

Sembra illeggibile, ma è solo il nome ufficiale di un prodotto e di una versione, scritto uguale in tutti gli avvisi del mondo. Si legge a pezzi, separati dai due punti. I primi cinque sono quelli che contano:

Pezzo	Nell'esempio	Cosa dice	Per te
`cpe:2.3`	`cpe:2.3`	la versione del formato	sempre uguale, si salta
tipo	`a`	`a` applicazione · `o` sistema operativo · `h` hardware	un firewall ha di solito un `o` (il suo sistema) e un `h` (la scatola)
produttore	`microsoft`	il nome del produttore, minuscolo e attaccato	è quello da confrontare con il tuo inventario
prodotto	`outlook`	il nome del prodotto	cerca questo, non il nome commerciale
versione	`2016`	la versione colpita	se la tua è diversa l'avviso può non riguardarti; `*` vuol dire tutte
aggiornamento	`*`	la patch o il service pack: la riga di Outlook 2013 ha `sp1` qui	`*` vuol dire qualsiasi; quando c'è, conta anche quella
gli altri sei	`*:*:*:*:*:*`	edizione, lingua, piattaforma, altro	quasi sempre `*`; `-` vuol dire «non applicabile»

Il motivo per cui esiste: un nome scritto sempre uguale lo può confrontare un programma. Se nel tuo inventario accanto a «Outlook» c'è scritto `cpe:2.3:a:microsoft:outlook:2016`, un programma può dirti da solo «questo avviso ti riguarda» senza che tu lo legga.

Quando le versioni colpite sono tante, l'NVD non fa una riga per ciascuna: scrive il CPE con `*` al posto della versione e accanto un intervallo, per esempio «fino alla 7.2.8 esclusa». La riga del CPE dà il nome, l'intervallo dà le versioni.

Le due domande, e la voce «soluzione»

A questo punto le domande sono due. **Ho quel prodotto?** Se sì, **la mia versione è fra quelle colpite?** Se la risposta è no a una delle due, l'avviso non ti riguarda, anche con il 9.8. Se è sì a tutte e due, è la cosa più urgente che hai oggi. Per rispondere alla seconda serve sapere cosa ci sia installato, e di solito è lì che ci si ferma.

È il punto di tutta la lezione, e vale la pena dirlo per esteso. Un avviso ti dice quanto sia grave una falla e in quali prodotti stia. Non ti dice se quei prodotti li hai, dove sono, se sono raggiungibili da Internet, chi li aggiorna: questo lo sai solo tu, e lo sai solo se te lo sei scritto. Se non conosci la tua infrastruttura non sai cosa difendere, e quindi non sai cosa aggiornare: ogni avviso diventa una domanda a cui non puoi rispondere, e la risposta più comoda è chiuderlo. Per questo la prima cosa da fare, e da rifare ogni volta che cambia qualcosa, è definire il perimetro: l'elenco di quello che c'è, a partire da quello che si vede da fuori. È la lezione 1, ed è il motivo per cui viene prima di questa.

Guarda poi cosa dice l'avviso alla voce soluzione. Quasi sempre è un aggiornamento (per Outlook, gli aggiornamenti di marzo 2023). A volte l'aggiornamento non c'è ancora: allora l'avviso dice cosa fare nel frattempo, di solito limitare chi può raggiungere il programma da fuori.

Le versioni vecchie e gli apparati fuori supporto (EOL)

Un avviso dice sempre quali versioni sono colpite, e quasi sempre la frase è «la versione X e tutte le precedenti». Cioè: se hai una versione più vecchia di quella, sei colpito anche tu.

Pensaci un momento. Prima dell'avviso la falla c'era già, ma la conoscevano in pochi. Dopo l'avviso la falla è scritta su una pagina pubblica, con sopra il nome del prodotto e l'elenco delle versioni vulnerabili. Chi attacca non deve scoprire niente: legge l'avviso come te, e poi cerca su Internet chi ha ancora una di quelle versioni.

Per le versioni recenti il produttore pubblica l'aggiornamento che chiude la falla. Per le versioni che non segue più no. Un prodotto è **EOL** (*end of life*, fine vita) quando il produttore ha smesso di aggiornarlo: lo dichiara con una data, e dopo quella data non escono più correzioni, nemmeno per le falle gravi. Un apparato EOL compare quindi in ogni avviso futuro del suo produttore, nella parte «e tutte le precedenti», e per lui non ci sarà mai niente da installare. Outlook 2013 è un buon esempio: la correzione di marzo 2023 l'ha avuta, perché il supporto finiva l'11 aprile 2023. Tutto quello che è uscito dopo, no.

In pratica un avviso è due cose insieme: per chi può aggiornare, una cosa da fare; per chi ha un apparato fuori supporto, la conferma di essere un bersaglio noto, senza rimedio. È il motivo per cui aggiornare non è una cosa da fare «quando c'è tempo», e un apparato fuori supporto esposto a Internet va sostituito o staccato, non tenuto d'occhio.

Due controlli semplici: per ogni apparato dell'inventario, segna la data di fine supporto (il produttore la pubblica, basta cercare «nome del prodotto end of life»); e quando leggi un avviso, guarda se la tua versione sia nella parte «precedenti».

Quando esce la PoC

Fra l'avviso e l'attacco c'è un passaggio che l'avviso non dice: la pubblicazione di una **PoC** (*proof of concept*), il codice che dimostra come si sfrutta la falla. Spesso esce pochi giorni dopo l'avviso, a volte lo stesso giorno, di solito su GitHub o nell'articolo di chi l'ha trovata. Per la falla di Outlook i dettagli tecnici e il codice erano pubblici entro la settimana. Da quel momento la falla non serve più saperla capire: basta saper copiare. Nelle ore successive partono le scansioni automatiche su tutta Internet alla ricerca degli apparati colpiti, e un apparato esposto viene trovato in giornata.

Il tempo che hai per aggiornare è quello fra l'avviso e la PoC, e non lo decidi tu. Nella lezione 3 vedremo i due elenchi che dicono se una falla sia già sfruttata e quanto sia probabile che lo sia: sono il modo per sapere se la PoC sia uscita senza doverla cercare.

Gli errori che vedo più spesso

- **Leggere solo il numero.** Un 9.8 su un programma che gira solo su un PC interno, dietro firewall, è meno urgente di un 7.5 sul firewall stesso.

- **Non sapere cosa c'è installato.** È l'errore più comune e quello che rende inutili tutti gli altri passi. Senza elenco non puoi dire se una versione ti riguardi.
- **Fidarsi della mail del fornitore che dice «nessuna azione richiesta».** Leggi lo stesso le versioni.
- **Trovare la pagina NVD senza punteggio e pensare che non sia grave.** Dal 2024 l'NVD è in ritardo su molti CVE: se manca il punteggio, leggi l'avviso del produttore, che di solito ce l'ha.
- **Aggiornare e non riavviare.** Molti aggiornamenti non sono attivi finché la macchina non riparte. Lo scanner continua a vedere la vulnerabilità e tu pensi che non abbia funzionato.

Come lo verifichi

Gli avvisi vanno fatti arrivare, non cercati: iscriviti agli avvisi del CSIRT Italia (gratis, in italiano, e segnala quando una falla è sfruttata davvero) e alla lista di sicurezza del produttore del tuo firewall e della tua VPN. Sono tre iscrizioni e bastano per un anno.

Il perimetro prima di tutto. Fatti un elenco, anche su un foglio di calcolo, con cinque colonne: apparato o programma, versione, raggiungibile da Internet (sì/no), chi lo aggiorna, data dell'ultimo aggiornamento. Comincia dagli apparati esposti: firewall, VPN, posta, siti, NAS, telecamere. Sono dieci righe, e sono le dieci che contano.

Se vuoi fare un passo in più, aggiungi una sesta colonna con il nome CPE del prodotto: nella sezione qui sotto c'è il modo di fartelo ricostruire dall'assistente, riga per riga. Con quella colonna, un programma può controllare da solo, ogni settimana, se è uscito un avviso per una delle tue dieci righe.

CON L'AI, PER QUESTA LEZIONE

Uso 2 di 12 · Farsi scrivere un piccolo strumento. Invece di incollare ogni avviso nella chat, fatti costruire una volta sola due cose: l'elenco dei CPE della tua azienda, e un programma che con quell'elenco interroga l'NVD e ti stampa solo quello che ti riguarda. L'NVD ha un'interfaccia pubblica e gratuita (`services.nvd.nist.gov/rest/json/cves/2.0`).

Primo passo: i CPE dell'azienda. Il nome CPE a mano non lo scrive nessuno, ma l'assistente lo ricostruisce bene se gli dai le informazioni giuste. Incollagli l'inventario così com'è, anche in parole povere, e chiedigli di farti le domande che gli mancano:

> `Questo è l'elenco di quello che c'è nella mia azienda: [incolla le righe, per esempio «firewall Fortinet 60F versione 7.2.8», «Outlook 2016», «Windows Server 2019», «NAS Synology DS923+ DSM 7.2»]. Per ogni riga ricostruisci il nome CPE 2.3 (tipo, produttore, prodotto, versione) come lo usa l'NVD. Se per una riga ti manca qualcosa per scriverlo bene, non indovinare: fammi una domanda alla volta (quale versione precisa? quale modello? è l'applicazione o il sistema operativo dell'apparato?) finché non hai quello che serve. Alla fine dammi una tabella con tre colonne: la mia riga, il CPE, e cosa ti ha fatto dubitare.`

Le domande che ti fa sono utili quanto il risultato: ogni «quale versione precisa?» a cui non sai rispondere è un buco dell'inventario. Il risultato lo verifichi: ogni CPE si cerca sull'NVD (https://nvd.nist.gov/products/cpe/search) e deve esistere, altrimenti il programma dopo non troverà mai niente e tu penserai di essere a posto.

Secondo passo: il programma. Con l'elenco verificato:

> `Scrivimi uno script in Python che legga un file di testo con un CPE per riga, interroghi l'API pubblica dell'NVD e stampi i CVE pubblicati negli ultimi sette giorni che riguardano quei CPE, con: codice, punteggio CVSS, vettore spiegato in italiano (da dove si sfrutta, se servono credenziali, se serve un clic), prodotto e versioni colpite. Niente librerie oltre a` `requests` `. Se l'API non risponde, dillo chiaramente invece di inventare.`

Lo provi una volta su un CVE che conosci (per Outlook 2016 e CVE-2023-23397 deve trovare la corrispondenza), poi lo fai girare il lunedì mattina. Senza chiave l'NVD accetta cinque richieste ogni trenta secondi: per dieci righe basta; se ne hai di più, la chiave si chiede gratis sul sito dell'NVD e lo script la mette in un'intestazione. Da quel momento gli avvisi non li leggi più: li ricevi filtrati sul tuo perimetro, e i dati arrivano dall'NVD, non dalla memoria dell'assistente.

DA FARE

Lunedì mattina, se sei l'unico informatico

1. Quando arriva un avviso con un codice CVE, cercalo su nvd.nist.gov. Lì trovi i prodotti e le versioni colpite. ☐
2. Controlla per prima cosa se la versione colpita sia quella che hai tu: se no, l'avviso non ti riguarda e il resto non serve. Per farlo serve sapere cosa ci sia installato: se non hai un elenco, questo è il primo lavoro da fare, prima di qualunque aggiornamento. Senza perimetro non sai cosa difendere. ☐
3. Se ti riguarda, guarda due cose: se si sfrutta dalla rete e se servono delle credenziali. Dalla rete senza credenziali è urgente. ☐

Glossario

Le sigle nuove di questa lezione, con due righe ciascuna: la prima per capirsi, la seconda per capire. Poi, in breve, quelle delle lezioni precedenti.

CVE NUOVA — Il codice univoco di una vulnerabilità nota, nel formato CVE-anno-numero (Common Vulnerabilities and Exposures). *Per capirla meglio:* Serve perché tutti chiamino la stessa falla con lo stesso nome: il produttore, chi la scopre, lo scanner, il bollettino. Un CVE è una vulnerabilità in un prodotto, non una categoria. I codici li assegnano le CNA, coordinate da MITRE; i dettagli si leggono sull'NVD.

CWE NUOVA — La categoria di una debolezza del software, per esempio «SQL injection» (Common Weakness Enumeration). *Per capirla meglio:* Il CWE è la classe del difetto, il CVE è il caso concreto in un prodotto preciso. Per te serve a capire di che tipo di errore si tratta: un CWE di iniezione di comandi su un apparato esposto vuol dire che qualcuno può fargli eseguire comandi suoi.

CVSS NUOVA — Il punteggio di gravità di una vulnerabilità, da 0 a 10 (Common Vulnerability Scoring System). *Per capirla meglio:* Misura quanto sia grave la falla in astratto: da dove si sfrutta, se servono credenziali, cosa compromette. Non misura quanto sia probabile che qualcuno la usi: per quello ci sono EPSS e KEV, nella lezione 3. Un 9.8 su un programma interno può essere meno urgente di un 7.5 sul firewall.

NVD NUOVA — La banca dati pubblica dei CVE, gestita dal NIST americano (National Vulnerability Database). *Per capirla meglio:* Prende i CVE e li arricchisce: punteggio CVSS, CWE, elenco dei prodotti e delle versioni colpite. È il posto dove verificare quello che ti dice un bollettino, uno scanner o un assistente AI. Ha anche un'interfaccia pubblica che si può interrogare con un programma.

CPE NUOVA — Il nome standard di un prodotto e di una versione, usato dall'NVD per dire cosa colpisca un CVE (Common Platform Enumeration). *Per capirla meglio:* Si legge `cpe:2.3:` seguito da tipo (a = applicazione, o = sistema operativo, h = hardware), produttore, prodotto, versione. Scrivere il CPE accanto a ogni riga dell'inventario è quello che trasforma un foglio di calcolo in una cosa che un programma può controllare al posto tuo.

EOL NUOVA — Fine del supporto di un prodotto: il produttore non pubblica più correzioni, nemmeno di sicurezza (End Of Life). *Per capirla meglio:* Un apparato fuori supporto compare negli avvisi di sicurezza come tutti gli altri, ma per lui non arriva la correzione: ogni falla nuova resta aperta. Nell'inventario la data di fine supporto vale quanto la versione, e un apparato fuori supporto esposto a Internet è la prima cosa da togliere o da sostituire.

PoC NUOVA — Il codice, o la procedura, che dimostra che una falla si può sfruttare davvero (Proof of Concept). *Per capirla meglio:* Finché non c'è, la falla è sulla carta; quando esce, chiunque può usarla copiandola. Esce di solito pochi giorni dopo l'avviso, e da quel momento gli apparati esposti vengono cercati in automatico su tutta Internet. È il motivo per cui «aggiorno al prossimo giro» su un apparato esposto spesso è troppo tardi.

NIST NUOVA — L'ente americano degli standard (National Institute of Standards and Technology). Gestisce l'NVD e pubblica le linee guida più usate. *Per capirla meglio:* Oltre all'NVD, dal NIST vengono il Cybersecurity Framework e le linee guida sulle password che hanno cambiato le regole (meglio lunghe che complicate, niente scadenza forzata). Quando un documento di sicurezza cita «NIST», di solito cita una di queste.

CNA NUOVA — Gli enti autorizzati ad assegnare i codici CVE: grandi produttori, CERT nazionali, ricercatori accreditati (CVE Numbering Authority). *Per capirla meglio:* Un produttore che è CNA assegna lui stesso il codice alle vulnerabilità dei suoi prodotti. Per te cambia poco, ma spiega perché a volte il codice esiste prima dei dettagli sull'NVD.

MITRE NUOVA — L'organizzazione americana senza scopo di lucro che coordina i CVE e gestisce ATT&CK. *Per capirla meglio:* Fa da arbitro: tiene l'elenco dei CVE e il catalogo delle tecniche di attacco. Non vende niente, e per questo i suoi cataloghi sono diventati la lingua comune del settore.

CERT NUOVA — Una squadra che risponde agli incidenti informatici, nazionale o di settore (Computer Emergency Response Team). *Per capirla meglio:* In Italia il riferimento è il CSIRT Italia dell'Agenzia per la cybersicurezza nazionale, che pubblica avvisi sulle vulnerabilità sfruttate. Iscriversi ai suoi avvisi è gratis ed è una buona fonte per il giro mensile.

EPSS NUOVA — Una stima, in percentuale, della probabilità che una vulnerabilità venga sfruttata nei prossimi trenta giorni (Exploit Prediction Scoring System). *Per capirla meglio:* È calcolata da FIRST sui dati di sfruttamento reali. Risponde alla domanda che il CVSS non fa: «ma qualcuno la usa davvero?». Si guarda come percentuale e come percentile: il 95° percentile vuol dire fra il 5% più sfruttato. Gratis, su first.org/epss.

AV, AC, PR, UI NUOVA — Le prime quattro sigle del vettore CVSS, quelle che dicono quanto sia facile entrare: da dove si attacca, quanto è difficile, se servono privilegi, se serve un'azione dell'utente. Le altre quattro (S, C, I, A) dicono cosa succeda dopo: se il danno esce dall'apparato e quanto si perde in riservatezza, integrità, disponibilità. *Per capirla meglio:* AV:N vuol dire dalla rete, AV:L in locale; AC:L senza condizioni particolari; PR:N senza credenziali; UI:N senza che nessuno clicchi. Una vulnerabilità AV:N, PR:N, UI:N su un apparato esposto è il caso peggiore: chiunque, da Internet, senza aiuto. La tabella completa è nella sezione «Il vettore».

SQL NUOVA — Il linguaggio con cui si interrogano le banche dati (Structured Query Language). *Per capirla meglio:* La «SQL injection» è l'attacco in cui si scrive del codice SQL in un campo di un sito (un modulo, una ricerca) e il sito lo esegue. È uno dei difetti più vecchi e ancora fra i più comuni nei portali aziendali.

XSS NUOVA — Un difetto di un sito che permette di far eseguire del codice nel browser di chi lo visita (Cross-Site Scripting). *Per capirla meglio:* Il codice malevolo arriva attraverso il sito stesso, per esempio in un commento o in un parametro dell'indirizzo, e gira nel browser della vittima con i suoi permessi: può rubare la sessione o far fare azioni a suo nome.

VPN NUOVA — Un collegamento cifrato da fuori verso la rete aziendale, come se si fosse in ufficio (Virtual Private Network). *Per capirla meglio:* È la porta d'ingresso più usata da chi lavora da remoto e, di conseguenza, da chi attacca: credenziali rubate e apparati VPN non aggiornati sono fra le prime cause di incidente. Va con il secondo fattore e sta in cima alla lista degli apparati da aggiornare.

NAS NUOVA — Un disco di rete condiviso, spesso usato per i file e per i backup (Network Attached Storage). *Per capirla meglio:* Comodo e per questo pericoloso: se è raggiungibile da tutta la rete con le stesse credenziali, un ransomware lo cifra insieme ai PC. Un NAS esposto a Internet con una vulnerabilità nota è una delle cose che un penetration test trova per prime.

API NUOVA — Un modo per far parlare due programmi fra loro, senza passare da una pagina web (Application Programming Interface). *Per capirla meglio:* Quando un sito «ha un'API» vuol dire che un tuo programma può chiedergli dati e riceverli in un formato leggibile da una macchina. L'NVD, il catalogo KEV e l'EPSS ne hanno una: è così che lo script della lezione 3 fa il giro da solo.

Dalle lezioni precedenti (la spiegazione completa è nella lezione in cui sono comparse):

CIA — Le tre cose da proteggere: riservatezza, integrità, disponibilità (in inglese Confidentiality, Integrity, Availability). Niente a che vedere con l'agenzia americana. *(lezione 1)*

ransomware — Un programma che cifra i file dell'azienda e chiede un riscatto per la chiave. Non è una sigla, ma è la parola che torna più spesso. *(lezione 1)*

DDoS — Attacco che manda a un servizio più richieste di quante ne regga, finché smette di rispondere. Sta per Distributed Denial of Service. *(lezione 1)*

HTTPS — La versione cifrata di HTTP, il protocollo delle pagine web. È il lucchetto nel browser. *(lezione 1)*

PLC — Il computer industriale che comanda una macchina o una linea di produzione (Programmable Logic Controller). *(lezione 1)*

IBAN — Il codice del conto corrente, quello che si scrive per fare un bonifico (International Bank Account Number). *(lezione 1)*

AI — Intelligenza artificiale. Qui vuol dire gli assistenti con cui si parla scrivendo, e i modelli che ci stanno dietro. *(lezione 1)*

Ing. Alessandro Manneschi
Cyber Security Architect · NIS2, monitoraggio e sicurezza per le PMI

Tutte le lezioni, gratis:
github.com/alevento/sicurezza-per-chi-e-solo
Licenza CC BY-NC-SA 4.0